

외부 공개용 문서

ODRE PQC v0.2.9

공개 기술 백서

한국어판

공개판 · 2026년 9월 2일

목차

1. 요약
2. 제품 목적과 범위
3. 아키텍처
4. 암호 프로파일
5. 보안 계약
6. 위협 모델과 신뢰 경계
7. 검증과 감사 결과
8. 크로스플랫폼 결과
9. 릴리스 규율과 증거
10. 배포 지침
11. 공개 범위
12. 결론

Document identity

Product	ODRE PQC
Version	0.2.9
Artifact	odre_pqc-0.2.9-py3-none-any.whl
Wheel SHA-256	A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697
Evidence manifest SHA-256	4AF2C88FDEA0CB1FB030E4AB6D5B41394CC52397664364233482E3EC14945F3B
Runtime cryptography	OpenSSL 3.5.8 / ML-KEM-768 / ML-DSA-65
Validated platforms	Windows Server 2022 AMD64; Ubuntu 24.04.4 LTS AMD64
Final audit verdict	ODRE_PQC_v0.2.9_FULL_DEVSEC_AUDIT_PASS

1. 요약

ODRE PQC는 서버의 보호 대상 라우트에 삽입되는 애플리케이션 내장형 포스트양자 보안 경계다. 암호 런타임 관리, 인증된 세션 수립, 엄격한 순서 검증, 재전송 방어, 요청·응답 의미 보호, 네이티브 파일 신뢰, 수명주기 제어와 fail-closed 집행을 작은 통합 표면 뒤에서 제품이 담당한다.

v0.2.9는 이 문서의 SHA-256으로 식별되는 봉인된 크로스플랫폼 배포 후보다. 동일한 wheel이 Windows Server 2022 AMD64와 Ubuntu 24.04.4 LTS AMD64에서 새 전체 개발보안 감사를 통과했다. 수행 범위에서 새로 확인된 Critical, High, Medium 제품 결함은 0건이다.

이 백서는 절대적 안전성을 주장하지 않는다. PASS는 명시된 산출물, 플랫폼, 위협 모델, 구성과 시험 범위에만 적용된다. 실제 운영 배포는 별도의 운영자 통제와 위험평가가 필요하다.

2. 제품 목적과 범위

이 제품은 TLS, 신원확인, 권한부여, 안전한 코딩, 패치, 호스트 보안, 백업, 모니터링을 대체하지 않는다. 선택된 비즈니스 라우트 앞에 추가 보안 경계를 제공하며, PQC 경계가 요청을 승인한 뒤에만 보호 대상 핸들러가 실행된다.

고객 통합은 의도적으로 단순하다. 제품을 초기화하고 진단·검증한 뒤 `install(app)`으로 애플리케이션에 등록하고 서버를 시작한 다음 인증된 상태를 확인한다. 운영체제 차이는 제품 내부의 플랫폼 어댑터와 네이티브 런타임 번들이 처리한다.

Integration model

1	<code>odre-pqc init</code>
2	<code>odre-pqc doctor</code>
3	<code>odre-pqc verify</code>
4	<pre>from odre_pqc import install install(app)</pre>
5	<code>server start → odre-pqc status</code>

3. 아키텍처

보안 경계는 애플리케이션 통합 계층, 입장 통제와 의미 바인딩, 하이브리드 PQC 핸드셰이크·세션 계층, 재전송·순서 상태, 보호 요청·응답 envelope, 플랫폼별 네이티브 신뢰 제어, 인증된 수명주기·상태 보고로 구성된다.

wire 계약은 `odre-pqc/3`으로 버전 관리된다. 핸들러가 보는 보호 요청 의미는 인증된 내부 의미와 일치한다. 보호 응답의 상태 코드, 순서가 보존된 헤더, 쿠키와 본문은 보호 프레임 안에 있고 외부에는 제한된 전송 메타데이터만 허용된다.

배포물은 하나의 Python wheel과 플랫폼별 런타임 번들로 구성된다. 봉인된 패키지는 메타데이터, 매니페스트, 네이티브 아카이브와 무결성 검사를 정확한 릴리스 신원에 결속한다.

4. 암호 프로파일

감사된 런타임은 OpenSSL 3.5.8이며 `OpenSSL_version_num`은 0x30500080이다. 양쪽 공식 운영체제에서 실제 ML-KEM-768, ML-DSA-65 자체시험과 하이브리드 핸드셰이크가 통과했다.

보호 라우트에서 PQC가 불능일 때 classical-only 보호로 조용히 내려가지 않는다. provider, 키, 세션, 재전송 상태, 네이티브 신뢰 또는 런타임 상태가 계약을 만족하지 못하면 비즈니스 핸들러 실행 전에 해당 경로를 차단한다.

5. 보안 계약

핵심 계약은 fail-closed다. 유효하지 않거나 모호한 입력, replay·sequence 위반, 세션·라우트 불일치, 인증되지 않은 상태, 신뢰할 수 없는 네이티브 객체, 초기화 실패와 안전하지 않은 종료 전환을 보호 실행 성공으로 바꾸지 않는다.

인증된 요청 의미와 핸들러가 관찰하는 의미는 같다. 보호 응답 의미는 기밀성과 무결성을 유지한다. 보안 민감 OS 실행파일과 네이티브 라이브러리는 신뢰된 객체에 바인딩된다. ON 상태는 살아 있는 런타임 인스턴스와 최신 상태에 인증된다. 보안 자원은 승인된 모든 보호 요청보다 오래 유지된다.

6. 위협 모델과 신뢰 경계

감사는 네트워크 변조, replay·동시성, 비정상·과대 입력, 의미 혼동, 응답 메타데이터 누출, 충돌·재시작 상태, 로컬 파일 교체, symbolic link·reparse 조작, 의존성·provider 주입과 수명주기 경쟁을 다뤘다.

기본 운영체제, CPU, Python 런타임과 권한 있는 관리자가 완전히 장악되지 않았다는 가정이 있다. 악성 커널, 무제한 관리자 권한, 물리 추출, 승인 뒤의 애플리케이션 로직 결함, 시험 범위 밖 서비스 거부 또는 미래 암호해독 돌파까지 막는다고 주장하지 않는다.

7. 검증과 감사 결과

봉인 wheel의 새 복사본을 hash-lock 방식으로 설치했다. 감사 시작·종료 SHA-256은 동일했다. 이전 보고서를 새 PASS 근거로 재사용하지 않았고 감사 중 제품 바이트를 변경하지 않았다.

정적 검토는 Python 38개 파일 7,160줄, 패키지 메타데이터, RECORD, 플랫폼 지원자료, 양쪽 네이티브 매니페스트와 런타임 아카이브를 포함했다. wheel RECORD 45/45 해시 항목이 통과했고 오염 파일은 0이었다. Python 의존성 19개에 대한 당시 신규 advisory 조회에서 조회 오류 0, 반환된 취약점 기록 0이었다.

감사 도구 문제 6건은 제품 결함과 분리했다. 도구를 수정한 뒤 영향받은 gate를 다시 실행했고 봉인된 제품 wheel은 그대로 유지됐다.

Published audit metrics

Metric	Windows	Ubuntu
Platform verdict	PASS	PASS
Replay-race requests	1,280	2,880
Double handler execution	0	0
Native load attempts	3,000	-
Atomic replacements observed	1,062	-
Junction create/remove cycles	3,000	-
Late-promotion parent swaps	-	600 / 600
Untrusted load / misbinding	0	0
Unresolved Critical / High / Medium	0 / 0 / 0	0 / 0 / 0

8. 크로스플랫폼 결과

Windows 검증에는 신규 초기화, 재초기화 차단, doctor, verify, status, 로그인 세션 전환, replay race, 요청·응답 바인딩, ACL 신뢰, 상태 인증, 종료 자원 수명, 프로토콜 변조, 충돌 복구와 네이티브 로드 스트레스가 포함됐다.

Ubuntu 검증에는 신규 초기화, 부정 진단, 실제 PQC, replay race, admission fuzz, 비정상·과대 입력, HTTP smuggling 형태, 응답 기밀성, WebSocket fail-closed, 네이티브 객체 신뢰, 동시 초기화, worker 충돌, 정상·강제 재시작과 parent-object race가 포함됐다.

9. 릴리스 규율과 증거

ODRE PQC는 불변 릴리스 신원을 사용한다. 감사 대상은 버전과 SHA-256으로 고정한다. 바이트가 바뀌면 새 산출물과 새 검증 주기가 필요하며 같은 버전 이름으로 몰래 재발행하지 않는다.

증거는 제품 결함, 감사 도구 문제, 환경 문제를 분리 기록한다. v0.2.9는 발견 제품 결함 0, 수정 제품 결함 0, 환경 문제 0, 미해결 Critical/High/Medium 0이다. 운영 네트워크 접촉은 0이며 운영 환경은 변경하지 않았다.

10. 배포 지침

운영자는 설치 전에 wheel SHA-256을 검증하고, 지원 OS·Python 기준선을 사용하며, 통제된 신규 환경에서 init, doctor, verify를 실행해야 한다. 이후 install(app)을 등록하고 애플리케이션 시작 후 인증된 상태를 확인한 다음 보호 트래픽을 허용한다.

배포에는 별도의 TLS 구성, 권한부여, 애플리케이션 보안 검토, secret 관리, 호스트 패치·강화, 로그·모니터링, 백업, rollback 계획과 변경통제가 함께 필요하다. 개발보안 감사 통과는 운영 위험평가를 대신하지 않는다.

11. 공개 범위

이 공개판은 개인키·secret, 운영 토폴로지, 고객 데이터, 정확한 내부 경로·운영 식별자, exploit script, 전체 harness source와 공격비용을 실질적으로 낮추는 절차 세부사항을 제외한다. 대신 외부 기술평가에 필요한 아키텍처, 보안 계약, 산출물 신원, 시험 범위·수치와 한계를 공개한다.

12. 결론

ODRE PQC v0.2.9는 봉인된 크로스플랫폼 애플리케이션 내장형 PQC 보안 경계다. 정확히 지정된 wheel이 양쪽 공식 OS에서 명시된 전체 개발보안 감사를 통과했다. 증거가 지지하는 최강의 주장은 범위가 명확하다. 이 산출물은 해당 시험 조건에서 해당 gate를 만족했고 확인된 미해결 Critical, High, Medium 제품 결함은 0건이다.

Artifact verification

SHA-256

A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697

Evidence manifest SHA-256

4AF2C88FDEA0CB1FB030E4AB6D5B41394CC52397664364233482E3EC14945F3B

Verification command

```
python -m pip hash odre_pqc-0.2.9-py3-none-any.whl
```

Publication note

Prepared from the sealed v0.2.9 full development-security audit record. Public claims are deliberately scoped to the exact artifact and executed evidence. ODRE AI · Korea · 2026